세 가지 판정 공백을 보완했습니다

기존 메뉴·배치를 유지했습니다. 결과 화면과 핵심만 4쪽에 담았습니다.

32개 기능 조건 통과
Workbench 10개 도구 + Mapper

5 / 5 실제 브라우저 통과
로그인·JS·저장/조회·비인증 차단

2 → 0 권한 비교 보류 감소
동일 15개 계정 대조 / 기준 5개 제외

GraphQL 조회·권한

이전 POST를 쓰기로 오인 / 400 거부 보류

개선 단일 query 조회 처리 + errors/data 구분

SQL 참·거짓 비교

이전 참 200 / 거짓 404가 별개 결과

개선 거짓 조건 반복 후 SQL 조건 차이 후보

업무 결과 검증

이전 음수 송금 200에서 결과 판정 공백

개선 잔액 1005 → 1010 / 증가 +5 후보 표시

권한 결과: 정탐 5 · 정상 대조 10 · 오탐 0 · 미탐 0 · 보류 0
대표 시나리오의 결과이며 전체 취약점 탐지율을 뜻하지 않습니다.

미실행 1건: Feature Mapper 브라우저 보조 확장 클릭 연동(기존 환경 제약).
환경: Burp Community 2026.3.3 / Chromium 146 / 원본 Vuln Bank + PGlite 0.5.10 (PG 18.6).
화면 증빙: 실제 실행 결과를 담은 확장 Swing 패널 렌더링. 수동 데스크톱 클릭 검증은 아닙니다.

GraphQL: 조회와 권한 거부를 구분합니다

관리자 200 허용 · Bob 400 권한 거부 · 비로그인 401 차단을 각각 판정했습니다.



기존 보류 2건을 해소했습니다. 원본 조회도 비교 직전에 재확인합니다.
단일 JSON query만 자동 처리하며, mutation·다중 연산·부분 데이터는 보수적으로 다룹니다.

SQL: 200 / 404 차이를 반복 확인합니다

실제 확장 결과 목록의 확대 화면입니다. 기준 2회 + 참 1회 + 거짓 2회 = 총 5회.

진단 결과 · 후보와 근거

000	기준 응답	200	6226874738
-01	기준 재검증	200	6226874738
001	근거 없음	200	6226874738' AND '1'='1' --
-02	거짓 조건 재검증	404	6226874738' AND '1'='2' --
002	SQL 조건 차이 후보	404	6226874738' AND '1'='2' --

관측: 기준 200 = 참 200 / 거짓 404가 두 번 동일

이전에는 “응답 변화”, 개선 후에는 “SQL 조건 차이 후보”로 연결합니다.

WAF·일반 필터도 차이를 만들 수 있으므로 SQL 주입 성공으로 확정하지 않습니다.

업무 규칙: 응답 코드 대신 잔액 변화를 봅니다

음수 송금 -5 이후 송금자의 잔액이 +5 늘었습니다. 설정한 증가 상한 0을 넘었습니다.

업무 규칙 위반 후보

판단 이유
설정한 숫자 변화 경계를 넘는 전후 상태를 관측했습니다. 권한 정책과 별개로 실제 업무 규칙과 동시 변경을 확인하세요.

다음 확인
아래 전후 값과 변화 경계를 확인하고, 동시 요청 없는 초기 상태에서 재현하세요. 업무 규칙 위반 후보이며 확정 판정이 아닙니다.

계정	응답	비교에서의 의미
admin	200 · 기준	기준 계정 원본과 같은 인증이므로 종합 판정에서 제외
wb_alice	200	업무 규칙 위반 후보 $.balance 1005 → 1010 변화 5 허용 경계 0 동시 변경/인과관계 확인 필요

wb_alice · 실제 처리 결과

업무 규칙 위반 후보 · $.balance 1005 → 1010 · 변화 5 · 허용 경계 0 · 동시 변경/인과관계 확인 필요

검증	변경 전	변경 후
$.balance	1005	1010

설정: 비교 설정 → 쓰기 전후 조회 → 숫자 증가 상한 초과 / $.balance / 경계 0
상태 변화의 후보입니다. 동시 변경을 배제하고 실제 업무 규칙과 맞는지 확인하세요.